

NAME: SANVIKA M NAIK

SRN: PES1UG24AM253

SEM: 5     SECTION: E

### SOFTWARE ENGINEERING LAB 01

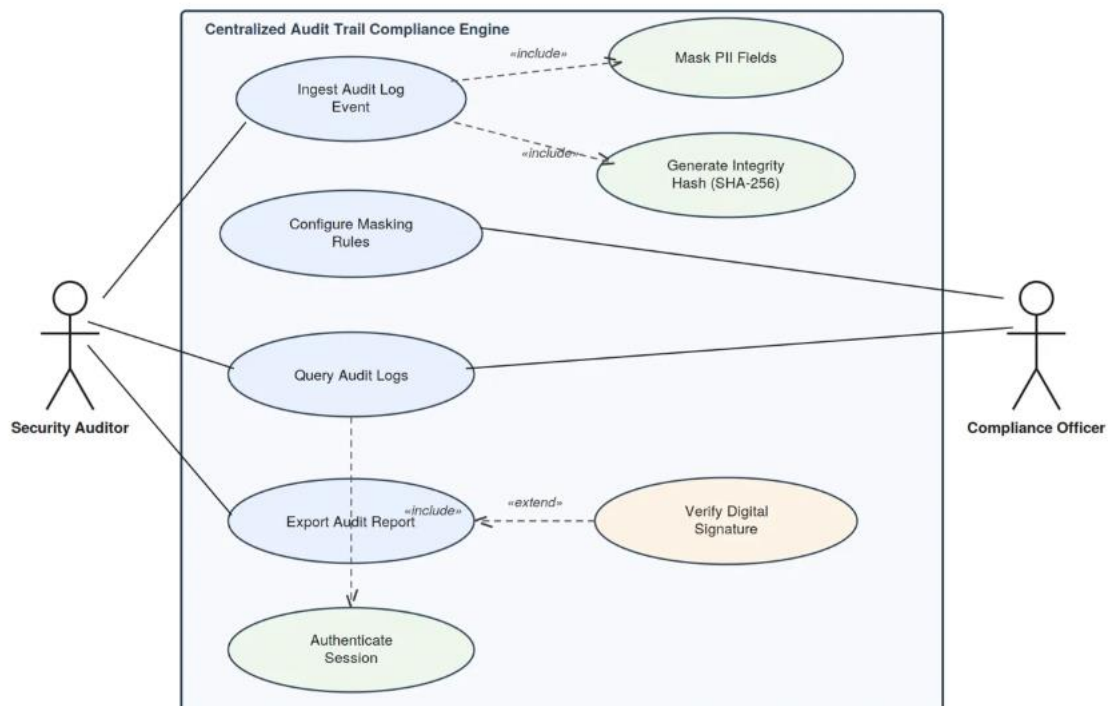
#### REQUIREMENTS TABLE

| ID     | TYPE       | DESCRIPTION                                                                                                                                                                | PRIORITY | ACCEPTANCE                                                                                        | RATIONALE                                                                                                                             |
|--------|------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|---------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------|
| FR-001 | Functional | The system shall parse structured JSON audit logs, identify and mask PII fields (Social Security Numbers, Credit Card Numbers) before persisting records to storage.       | HIGH     | Masked audit log saved with SHA-256 integrity hash.                                               | GDPR Article 32 requires pseudonymization/masking of personal data at rest to limit exposure if the data store is breached.           |
| FR-002 | Functional | The system shall compute a SHA-256 hash for each ingested audit record and chain it to the previous record's hash so that tampering with historical records is detectable. | HIGH     | Altering any historical record breaks the hash chain and is flagged by the integrity verification | Auditors and regulators must be able to trust that logs have not been altered after the fact; hash chaining provides tamper-evidence. |
| FR-003 | Functional | The system shall allow a Compliance Officer to define and update PII-masking rules                                                                                         | MEDIUM   | A newly configured field (e.g., passport number) is masked in all logs ingested                   | Source application log schemas evolve over time; compliance staff need to react to new PII fields without engineering involvement.    |

|        |            |                                                                                                                                                                                               |        |                                                                                                      |                                                                                                                                |
|--------|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------|
|        |            | (field name, pattern/regex, masking method) via an administrative interface without a code deployment.                                                                                        |        | after the rule is saved.                                                                             |                                                                                                                                |
| FR-004 | Functional | The system shall allow a Security Auditor to search and filter audit logs by actor, event type, date range, and source application, and view results in a paginated table.                    | HIGH   | A filtered query returns only records matching all specified criteria within the performance target. | Investigations and regulatory audits require auditors to quickly narrow down relevant events among millions of records.        |
| FR-005 | Functional | The system shall generate a digitally signed, immutable export bundle (PDF/CSV plus manifest) of selected audit records that can be independently verified for authenticity and completeness. | MEDIUM | The exported bundle's signature verifies successfully and its manifest hash matches the contents     | External regulators need a portable, verifiable evidence package that proves the export has not been altered after generation. |

| ID      | TYPE           | DESCRIPTION                                                                                                                                                               | PRIORITY | ACCEPTANCE                                                                                              | RATIONALE                                                                                                                                                   |
|---------|----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|---------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
| NFR-001 | NON FUNCTIONAL | Audit log query endpoints must support complex filtering across 10 million historical records in under 1 second.                                                          | HIGH     | Benchmarking tests confirm target latency and security standards under simulated peak load.             | Slow queries make real-time compliance investigations impractical at enterprise log volumes and discourage auditors from using the tool.                    |
| NFR-002 | NON FUNCTIONAL | All audit data must be encrypted at rest (AES-256) and in transit (TLS 1.3); PII masking must be irreversible so original values cannot be recovered from stored records. | HIGH     | Security review confirms AES-256 at rest, TLS 1.3 in transit, and no reversible masking function exists | GDPR requires appropriate technical measures to protect personal data; irreversible masking prevents re-identification even if the database is compromised. |

## UML DIAGRAM



## SCENARIOS

### Preconditions

1. The source application is registered and authenticated to send audit log events to the ingestion API.
2. The Compliance Officer has configured at least a baseline set of PII-masking rules (e.g., SSN, credit card number).
3. The audit log storage service and hash-chain (previous record hash) are available.

### Postconditions

1. Success: A masked audit record is persisted with a SHA-256 integrity hash linked to the existing hash chain, and the ingestion is marked complete.
2. Failure: No record is persisted to the primary store; the payload is quarantined and an ingestion error is logged.

### Main Success Scenario

1. The source application sends a structured JSON audit log event to the ingestion API endpoint.

2. The system validates the payload against the expected audit log schema (required fields, data types).
3. The system identifies PII fields in the payload based on the Compliance Officer's configured masking rules («include: Mask PII Fields»).
4. The system masks the identified PII fields (e.g., Social Security Numbers, Credit Card Numbers) using the configured, irreversible masking method.
5. The system computes a SHA-256 integrity hash for the masked record and chains it to the previous record's hash («include: Generate Integrity Hash»).
6. The system persists the masked, hashed record to the audit log data store.
7. The system updates the ingestion status and returns a success acknowledgement to the source application.
8. The Security Auditor can subsequently view the newly ingested record in the audit log dashboard.

Alternate Flow — Malformed Log Payload Trigger: Occurs at step 2, when the incoming payload fails schema validation.

1. The system rejects the payload and does not persist it to the primary audit log store.
2. The system writes the payload to a quarantine queue together with error metadata (reason, timestamp, source application).
3. The system sends an ingestion-failure notification to the source application and to the monitoring channel.
4. The use case ends without a persisted audit record; the Security Auditor can review quarantined items separately.